



INSTITUTO POLITÉCNICO DE BEJA
Escola Superior de Tecnologia e Gestão
Mestrado em Engenharia de Segurança Informática
Segurança no Software e Usabilidade

Vaulted Pass™

Martinho José Novo Caeiro - 23917
Paulo António Tavares Abade - 23919
Rafael Conceição Narciso - 24473



Beja, junho de 2026

INSTITUTO POLITÉCNICO DE BEJA
Escola Superior de Tecnologia e Gestão
Mestrado em Engenharia de Segurança Informática
Segurança no Software e Usabilidade

Vaulted Pass™

Martinho José Novo Caeiro - 23917
Paulo António Tavares Abade - 23919
Rafael Conceição Narciso - 24473

Orientadores:
Luís Felipe Nobre Horta Batista Garcia
Luís Carlos da Silva Bruno

Beja, junho de 2026

Resumo

Este trabalho analisa o desenho de um sistema de autenticação para dispositivos móveis centrado no equilíbrio entre segurança e usabilidade. O foco está na proteção contra observação direta do PIN, num contexto em que o utilizador desbloqueia frequentemente o telemóvel ou aplicações sensíveis em locais públicos.

A partir dessa necessidade foi desenvolvido o protótipo *Vaulted PassTM*, com quatro variações de introdução do PIN: teclado padrão, teclado embaralhado, cadeado padrão e cadeado embaralhado. O objetivo é comparar formas de autenticação que reduzam a exposição do código sem tornar a tarefa demasiado lenta ou difícil de aprender.

Keywords: autenticação, PIN, usabilidade, *shoulder surfing*, segurança.

Abstract

This work analyzes the design of a mobile authentication system focused on balancing security and usability. The emphasis is on protecting PIN entry against direct observation in public or semi-public settings.

The resulting prototype, *Vaulted Pass™*, includes four PIN-entry variations: standard keypad, scrambled keypad, standard padlock, and scrambled padlock. The goal is to compare authentication approaches that reduce exposure without making the task too slow or hard to learn.

Keywords: authentication, PIN, usability, shoulder surfing, security.

Índice

1	Introdução	1
2	Revisão Bibliográfica	1
3	Análise do Sistema	2
3.1	As 11 Questões Fundamentais da Análise de Tarefas	2
3.2	Caracterização dos Utilizadores	3
3.3	Cenários de Utilização	4
3.4	Análise de Tarefas	5
3.5	Versão Base: Autenticação por PIN com Teclado Digital Estático	6
3.6	Primeira Variante: Autenticação por PIN com Teclado Digital Embaralhado . . .	6
3.7	Segunda Variante: Autenticação por PIN com Forma de Cadeado Estática	6
3.8	Terceira Variante: Autenticação por PIN com Forma de Cadeado Embaralhada .	6
4	Desenho do Sistema	7
4.1	Interfaces dos Equipamentos Físicos e Ecrãs	7
4.2	Diagramas de Navegação	8
4.3	Princípios e Regras de Usabilidade	8
5	Implementação e Avaliação do Protótipo	9
5.1	Implementação do Protótipo	9
5.2	Avaliação do Protótipo	9
6	Testes com Utilizadores	10
7	Conclusão	11
	Bibliografia	11

Índice de Figuras

1	Protótipo de média fidelidade da aplicação.	7
---	---	---

1 Introdução

Este trabalho analisa o desenho de um sistema de autenticação para dispositivos móveis centrado no equilíbrio entre segurança e usabilidade. O foco está na proteção contra observação direta do PIN, num contexto em que o utilizador desbloqueia frequentemente o telemóvel ou aplicações sensíveis em locais públicos.

A partir dessa necessidade foi desenvolvido o protótipo *Vaulted Pass™*, com quatro variações de introdução do PIN: teclado padrão, teclado embaralhado, cadeado padrão e cadeado embaralhado. O objetivo é comparar formas de autenticação que reduzam a exposição do código sem tornar a tarefa demasiado lenta ou difícil de aprender.

2 Revisão Bibliográfica

Foram analisados dois trabalhos científicos diretamente relacionados com autenticação por PIN resistente a observação.

O primeiro artigo, *A PIN-entry method resilient against shoulder surfing*, de Roth, Richter e Freidinger, propõe métodos alternativos de entrada de PIN baseados em *cognitive trapdoor games* (Roth et al., 2004). A ideia central é dificultar a captura do PIN mesmo quando o atacante observa todo o processo de entrada, incluindo gravações em vídeo. Os autores estudam simultaneamente segurança e usabilidade e concluem que é possível aumentar de forma relevante a resistência a ataques de *shoulder surfing* sem destruir por completo a viabilidade prática do método. Para este projeto, o principal contributo do artigo foi mostrar que a interface pode alterar significativamente o nível de exposição do PIN, mesmo mantendo a mesma credencial.

O segundo artigo, *A rotary PIN entry scheme resilient to shoulder-surfing*, apresenta um esquema de entrada do PIN do tipo "roda giratória" que também resiste à observação humana e a gravações curtas (Shi et al., 2009). O trabalho mostra duas variantes da solução e procura um compromisso entre segurança e esforço de interação. O resultado mais relevante para este relatório é a demonstração de que um mecanismo visual e rotativo pode ser compreendido pelo utilizador após curta aprendizagem, ao mesmo tempo que reduz a utilidade de um ataque por observação. Este princípio foi usado no desenho da variante em forma de cadeado do protótipo.

Em conjunto, estes artigos sustentam a opção por comparar uma interface tradicional com alternativas visuais e baralhadas, permitindo estudar se a segurança adicional compensa o custo cognitivo imposto ao utilizador.

3 Análise do Sistema

3.1 As 11 Questões Fundamentais da Análise de Tarefas

1. **Quem vai utilizar o sistema?** Utilizadores de smartphones que procuram maior privacidade e segurança, abrangendo desde pessoas tecnologicamente avançadas até utilizadores com reduzida literacia digital ou séniores.
2. **Que tarefas executam atualmente?** Desbloqueio de dispositivos e aplicações por métodos biométricos (impressão digital, reconhecimento facial) ou por PIN/senhas, frequentemente em espaços onde terceiros podem observar o ecrã.
3. **Que tarefas são desejáveis?** Autenticação robusta que proteja dados sensíveis (bancários, saúde, mensagens) contra observadores externos, mantendo memorização e rapidez no acesso.
4. **Como se aprendem as tarefas?** Por experimentação direta e através de um curto tutorial inicial (onboarding) que explica a lógica dos métodos embaralhados e rotativos.
5. **Onde são desempenhadas as tarefas?** Em contextos móveis: transportes públicos, cafés, filas, ruas — ambientes com risco de observação lateral.
6. **Qual a relação entre o utilizador e a informação?** O utilizador é o titular legítimo dos dados; o sistema atua como gatekeeper, validando a identidade antes de liberar acesso.
7. **Que outros instrumentos tem o utilizador?** Ecrã tátil do smartphone, memória visual/motora e, opcionalmente, acessórios (stylus) ou funcionalidades de acessibilidade do SO.
8. **Como comunicam os utilizadores entre si?** A autenticação é individual; contudo, o desenho deve prevenir que a observação de entradas revele a senha.

9. **Qual a frequência de desempenho das tarefas?** Elevada — o desbloqueio é recorrente ao longo do dia, exigindo soluções eficientes e pouco intrusivas.
10. **Quais as restrições de tempo impostas?** A autenticação deve ser rápida (idealmente $< 30s$). Em caso de várias tentativas falhadas, deve aplicar-se um tempo de espera para mitigar ataques.
11. **Que acontece se algo correr mal?** Feedback imediato ao utilizador (ex.: "PIN Incorreto"); em falhas repetidas, mecanismos de recuperação (email, código mestre) e registo de tentativas suspeitas.

3.2 Caracterização dos Utilizadores

Os utilizadores-alvo podem ser caracterizados como pessoas com uso frequente de smartphone e aplicações pessoais sensíveis. Há três perfis especialmente relevantes: utilizadores jovens e tecnologicamente confortáveis, que valorizam rapidez; utilizadores adultos que procuram um equilíbrio entre segurança e conveniência; e utilizadores seniores, que beneficiam de interfaces mais explícitas e de menor carga de memória.

Em termos de contexto, o nível de escolaridade e a formação em informática variam bastante, pelo que o sistema não pode depender de conhecimento técnico prévio. Se fosse possível contactar utilizadores e organizações, seria importante recolher dados sobre frequência de utilização do telemóvel, experiências anteriores com métodos de autenticação, dificuldades de acessibilidade, tempo aceitável para desbloqueio e perceção real de risco em espaços públicos.

3.3 Cenários de Utilização

Persona 1: Ricardo (O Analista Urbano)

- **Perfil:** 28 anos, tecnológico, vive em Lisboa e usa transportes públicos.
- **Cenário:** O Ricardo está num metro lotado e precisa de consultar o saldo bancário. Tem receio que alguém ao seu lado memorize o seu PIN.
- **Aplicação no protótipo:** Utiliza o *PIN Baralhado*. Como os números mudam de posição a cada acesso, mesmo que alguém observe o movimento dos dedos, não conseguirá replicar a sequência noutra sessão.

Persona 2: Dona Maria (A Utilizadora Sénior)

- **Perfil:** 72 anos, reformada, com dificuldades visuais.
- **Cenário:** Deseja desbloquear o telemóvel para mostrar fotografias a familiares, mas sofre com a leitura de pequenos dígitos.
- **Aplicação no protótipo:** Utiliza o *PIN em Forma de Cadeado*. Ao rodar o número de vezes necessárias a partir do ponto zero, recorre à memória gestual, tornando o acesso mais intuitivo e menos stressante.

Persona 3: Tiago (O Estudante Dinâmico)

- **Perfil:** 21 anos, estudante de engenharia, em movimento constante.
- **Cenário:** Corre para a faculdade com mochila e precisa de validar um bilhete digital enquanto caminha entre a multidão.
- **Aplicação no protótipo:** Utiliza o *PIN Forma Cadeado Baralhado*. É a variante de segurança máxima: exige rodar o cadeado enquanto os números estão em posições aleatórias, reduzindo a possibilidade de decifração por observadores distantes.

3.4 Análise de Tarefas

A tarefa principal é autenticar o utilizador com um PIN sem expor o código a observadores.

Sequência de Tarefas:

1. Pre-Configuração:

- (a) Definir o PIN numérico.
- (b) Confirmar o PIN para evitar erros de digitação.
- (c) Escolher o tipo de PIN: Normal, Baralhado, Forma Cadeado, ou Forma Cadeado Baralhado.

2. Processo de Autenticação (rotina diária):

- (a) Ativar o ecrã de desbloqueio (abrir a app ou ligar o ecrã).
- (b) Observar a disposição do teclado (identificar se os números estão na posição padrão ou baralhados).
- (c) Introduzir os dígitos ou rodar a "forma de cadeado"conforme a lógica do método ativo.
- (d) Submeter a tentativa de acesso (automático ao atingir o número de dígitos ou via botão "OK").

Nos métodos tradicionais a tarefa é direta, mas mais vulnerável a observação; nos métodos embaralhados, o utilizador interpreta a disposição atual dos números; na variante em forma de cadeado, a ênfase passa para a memória gestual e no feedback visual dos dials. Em caso de erro, o sistema permite corrigir a tentativa e fornece feedback imediato sem penalizar indevidamente o utilizador legítimo.

3.5 Versão Base: Autenticação por PIN com Teclado Digital Estático

Esta versão representa o método convencional, com teclado fixo e ordenação previsível dos números. É a solução mais rápida e familiar, mas também a mais vulnerável a *shoulder surfing*, gravação por câmara e observação lateral. Serve como base de comparação para medir o custo de segurança das restantes variantes.

3.6 Primeira Variante: Autenticação por PIN com Teclado Digital Embaralhado

A primeira variante altera a posição dos números em cada acesso. O objetivo é reduzir a utilidade da observação visual, porque um atacante que memorize a posição dos toques numa sessão terá dificuldade em repetir a sequência noutra sessão. Esta solução mantém a lógica clássica do PIN, mas obriga o utilizador a olhar para o teclado em cada autenticação.

3.7 Segunda Variante: Autenticação por PIN com Forma de Cadeado Estática

A variante em forma de cadeado traduz a introdução do PIN para um mecanismo visual de rotação. Em vez de tocar diretamente em botões fixos, o utilizador ajusta cada dígito até ao valor pretendido. A vantagem é tornar a leitura do código menos óbvia para um observador, ao mesmo tempo que introduz uma associação visual mais forte entre ação e número.

3.8 Terceira Variante: Autenticação por PIN com Forma de Cadeado Embaralhada

Na variante embaralhada da forma de cadeado, a disposição dos números muda, aumentando ainda mais a resistência à observação. Em contrapartida, o esforço cognitivo cresce, pelo que o desenho deve privilegiar feedback claro, legibilidade e consistência.

4 Desenho do Sistema

4.1 Interfaces dos Equipamentos Físicos e Ecrãs

O protótipo foi desenhado para simular uma aplicação móvel simples, com três ecrãs principais: configuração inicial, ecrã de autenticação e ecrã de resultado.

No ecrã inicial o utilizador escolhe o PIN e a variante de autenticação. No ecrã de teste é apresentada a interface correspondente à variante selecionada, com teclado numérico ou dials em forma de cadeado. No ecrã final surge o tempo de execução, a variante usada e o resultado da tentativa.

As interfaces físicas foram pensadas para comunicação clara e baixo ruído visual, com foco nos elementos essenciais: identificação do método, introdução do PIN, botão de confirmação e feedback de erro ou sucesso.

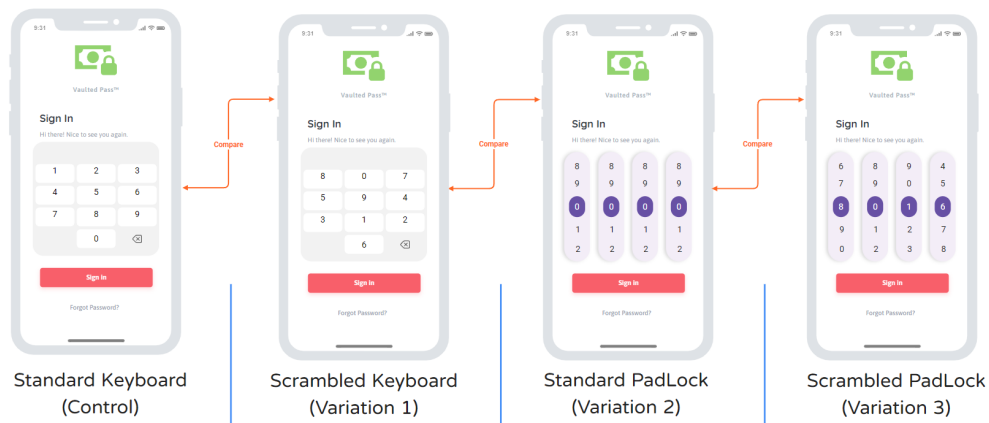


Figura 1: Protótipo de média fidelidade da aplicação.

4.2 Diagramas de Navegação

O fluxo principal do sistema é linear: configuração inicial → autenticação → resultado → regresso ao menu inicial. Em caso de erro no PIN, o utilizador permanece no ecrã de autenticação e pode corrigir a introdução antes de confirmar novamente.

Esta navegação simples reduz a carga de aprendizagem e evita que o utilizador tenha de memorizar caminhos complexos entre ecrãs. Como o objetivo do projeto é avaliar o método de entrada do PIN e não a exploração da aplicação, a estrutura de navegação foi mantida intencionalmente curta.

4.3 Princípios e Regras de Usabilidade

Foram aplicados vários princípios de usabilidade considerados centrais neste projeto:

- **Visibilidade do estado do sistema:** o temporizador e o ecrã de resultado mostram sempre o estado atual da interação.
- **Consistência:** os botões, cores e linguagem visual mantêm-se entre as variantes.
- **Prevenção de erros:** o campo do PIN aceita apenas dígitos e o sistema pede confirmação explícita.
- **Reconhecimento em vez de memória:** os métodos visuais mostram o valor atual de forma direta, reduzindo a necessidade de recordar passos anteriores.
- **Feedback imediato:** cada tentativa termina com indicação clara de sucesso ou falha.
- **Simplicidade:** a interface evita opções desnecessárias e concentra-se na tarefa principal.

Além destes princípios, o desenho procurou respeitar a legibilidade e a robustez da interação em ecrãs pequenos, privilegiando controlos grandes e um contraste visual suficiente para uso em contexto móvel.

5 Implementação e Avaliação do Protótipo

5.1 Implementação do Protótipo

O protótipo funcional foi implementado em Python com Kivy, usando `ScreenManager` para alternar entre o ecrã de configuração, o ecrã de teste e o ecrã de resultado. A lógica principal separa quatro modos: teclado padrão, teclado embaralhado, cadeado padrão e cadeado embaralhado.

O teclado numérico é gerado dinamicamente e, na variante embaralhada, a ordem dos números é aleatorizada em cada sessão. Na variante em forma de cadeado, o utilizador interage com dials verticais, o que permite simular uma entrada mais visual e menos dependente da leitura direta do teclado.

O protótipo mede o tempo de execução, regista o melhor desempenho por modo e apresenta feedback imediato após cada tentativa. Estas decisões foram tomadas para suportar uma avaliação comparativa da interface e do comportamento do utilizador.

5.2 Avaliação do Protótipo

O protótipo já permite avaliar diferenças de desempenho entre os vários modos, tanto em termos de rapidez como de facilidade de compreensão. A versão padrão serve como referência de comparação, enquanto as variantes embaralhada e em cadeado permitem estudar o impacto de mecanismos de segurança adicionais na interação.

Para uma avaliação final com utilizadores, deverá ser recolhido o tempo de execução, o número de erros, a preferência subjetiva e a perceção de segurança. Esses dados permitirão discutir se o aumento de proteção justifica o esforço adicional imposto pela interface.

6 Testes com Utilizadores

7 Conclusão

O trabalho consolidou uma abordagem de autenticação por PIN centrada na resistência à observação e na comparação entre diferentes estilos de interação. A revisão bibliográfica mostrou que existem soluções eficazes para reduzir o risco de *shoulder surfing* sem sacrificar totalmente a usabilidade, e o protótipo desenvolvido materializa esses princípios em quatro variantes distintas.

Do ponto de vista do desenho, a principal conclusão é que segurança e usabilidade não são objetivos incompatíveis, mas exigem compromissos visíveis na interface. O protótipo permite agora avançar para uma avaliação com utilizadores, onde será possível confirmar qual das variantes oferece o melhor equilíbrio entre rapidez, memorização e proteção.

Bibliografia

- Roth, V., Richter, K., & Freidinger, R. (2004). *A PIN-entry method resilient against shoulder surfing* [Artigo sobre método de entrada de PIN resistente a observação]. Obtido maio 25, 2026, de <https://dl.acm.org/doi/10.1145/1030083.1030116>
- Shi, P., Zhu, B., & Youssef, A. (2009). *A rotary PIN entry scheme resilient to shoulder-surfing* [Artigo sobre entrada rotativa de PIN resistente a observação]. Obtido maio 25, 2026, de <https://users.encs.concordia.ca/~youssef/Publications/Papers/A%20Rotary%20PIN%20Entry%20Scheme%20Resilient%20to%20Shoulder-Surfing.pdf>